

中华人民共和国通信行业标准

YD/T [×××××]—[××××]
[代替 YD/T]

基于公众电信网的体育赛事网络安全总体要求

General requirements for network security technology of sports games based on
public telecommunication network

[点击此处添加与国际标准一致性程度的标识]

(报批稿)

[点击此处添加本稿完成日期]

[××××]-[××]-[××]发布

[××××]-[××]-[××]实施

中华人民共和国工业和信息化部 发布

目 次

前言..... III

1 范围..... 1

2 规范性引用文件..... 1

3 术语和定义..... 1

4 基本要求..... 1

5 防护对象分类..... 2

6 防护要求分级..... 2

7 技术要求..... 2

 7.1 基础网络安全..... 2

 7.2 网络访问隔离..... 3

 7.3 移动网络接入..... 3

 7.4 通信线路要求..... 3

 7.5 资源控制要求..... 4

 7.6 集中管控要求..... 4

 7.7 数据与灾备安全..... 4

 7.8 资产跟踪和监测..... 4

 7.9 安全审计要求..... 5

 7.10 接口安全要求..... 5

前 言

本文件按照GB/T 1.1-2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》给出的规则起草。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别这些专利的责任。

本文件由中国通信标准化协会提出并归口。

本文件起草单位：西安邮电大学、中国信息通信研究院、陕西省信息化工程研究院、北京奇虎科技有限公司、中国联合网络通信集团有限公司、新华三技术有限公司、中兴通讯股份有限公司、中国信息通信科技集团有限公司、杭州安恒信息技术股份有限公司。

本文件主要起草人：张勇、朱志祥、吴晨、胡键伟、彭琴、张屹、陶冶、万晓兰、霍玉臻、张祺琪、徐雷、孙传闯、薛蓉娜、汪陈伍、任学强、潘正泰、王辉、梁伟、刘玉梅、岳玲、魏鹏飞、刘巍然。

基于公众电信网的体育赛事网络安全总体要求

1 范围

本文件给出了体育赛事信息系统的网络安全基本要求、防护对象分类分级以及技术要求。
本文件适用于指导体育赛事信息系统的网络与信息安全设计、实施、评测、服务、验收工作。

2 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中，注日期的引用文件，仅该日期对应的版本适用于本文件；不注日期的引用文件，其最新版本（包括所有的修改单）适用于本文件。

GB/T 25069 信息安全技术 术语

3 术语和定义

GB/T 25069中界定的以及下列术语和定义适用于本文件。

3.1

体育赛事 sports games

以体育竞技运动为核心的具有一定影响力的现场活动和服务。

3.2

资产 asset

对组织具有价值的信息系统软硬件或资源。

4 基本要求

基本要求包括如下：

- a) 应满足国家、行业有关法律、法规的要求；
- b) 应采用先进、成熟、适用、安全的信息技术和产品，并拒绝使用具有风险、未经严格检测、过度冗余或具有安全隐患的信息技术和产品；
- c) 应为系统调试和演练预留足够的时间，保证调试和演练的次数、质量和效果；
- d) 应有专职的安全服务机构，并与外部服务机构对接共同提供安全运行保障；
- e) 应综合利用人防与技防等手段，保证赛事期间信息系统平稳、有效、安全地运行；
- f) 赛时期间未经特别许可不得修改网络和信息系統。

5 防护对象分类

体育赛事的网络安全保护对象根据防护目标信息系统的重要程度分为一般对象、核心对象和关键对象，划分按照影响体育竞赛活动的程度区分，防护对象的划分如表 1 所示。

表 1：防护对象的划分范围

防护对象	划分方式
关键对象	对体育竞赛活动起支撑作用的网络和信息系统，出现问题后会 导致竞赛活动无法正常进行
核心对象	与体育竞赛活动关联紧密的辅助支撑系统，出现问题后会对竞 赛活动造成较大影响
一般对象	其他体育赛事网络和信息系统，出现问题后会对竞赛活动造成 一定影响

6 防护要求分级

体育赛事网络安全分为一般要求和增强要求，增强要求是对一般要求的补充和强化，在实现增强要求时，一般要求首先得到满足。安全要求与防护对象的对应关系如表 2 所示。

表 2：防护对象与安全要求对应表

防护对象	一般要求	增强要求
一般对象	应	可
核心对象	应	宜
关键对象	应	应

7 技术要求

7.1 基础网络安全

7.1.1 一般要求

本项的一般要求应包括：

- a) 网络边界部署边界防护设备，对跨区域的访问和数据流进行监控和防护；
- b) 对非授权设备私自连接体育赛事网络以及内部网络用户私自链接外部网络的行为进行检查，
准确定出位置，并对其进行有效阻断；
- c) 无线网络与有线网络边界之间的访问和数据流通过无线接入网关设备。

7.1.2 增强要求

本项的增强要求应包括：

- a) 限制信息系统外部访问接入点的数量，以便对进出通信和网络流量实施有效监控。
- b) 信息系统的外部通信接口经授权后方可传输数据；
- c) 提供独立的管理网络和管理工具。

7.2 网络访问隔离

7.2.1 一般要求

本项的一般要求应包括：

- a) 赛事专网与赛事管理网、赛事互联网实行物理隔离；
- b) 赛事管理网和赛事互联网实行物理隔离；
- c) 赛事互联网与互联网实行逻辑隔离；
- d) 支持云租户虚拟网络之间的隔离。

7.2.2 增强要求

无。

7.3 移动网络接入

7.3.1 一般要求

本项的一般要求应包括：

- a) 移动网络接入选择符合国家和行业相关标准的安全认证协议，实现双向身份认证；
- b) 支持移动/无线接入网络安全访问控制；
- c) 支持接入设备的鉴别和验证；
- d) 支持接入设备、用户访问行为的安全审计。

7.3.2 增强要求

无。

7.4 通信线路要求

7.4.1 一般要求

本项的一般要求包括：

- a) 选择一主一备两条线路并应能够实现无缝切换；
- b) 宜提供 5G（第五代移动通信技术）网络作为应急传输网络，网络带宽能够满足关键核心业务需要。

7.4.2 增强要求

本项的增强要求包括：

- a) 选择一主一备两个运营商，两个运营商之间应能够实现无缝切换。

7.5 资源控制要求

7.5.1 一般要求

本项的一般要求应包括：

- a) 应用系统的通信双方中的一方在一段时间内未作任何响应，另一方应能够自动结束会话；
- b) 能对多重并发会话进行限制；
- c) 能对一个访问帐户或一个请求进程占用的资源分配最大限额和最小限额；
- d) 能在资源水平降低到预先规定的最小值进行检测和报警。

7.5.2 增强要求

无。

7.6 集中管控要求

7.6.1 一般要求

本项的一般要求应包括：

- a) 划分出安全运维管理区，对分布在网络中的安全设备或安全组件进行集中部署和管控；
- b) 采用安全的远程管理方式对网络中的安全设备或组件进行管理；
- c) 提供安全态势感知能力。

7.6.2 增强要求

本项的增强要求应包括：

- a) 支持集中管理和下发安全策略。

7.7 数据与灾备安全

7.7.1 一般要求

本项的一般要求应包括：

- a) 采用符合国家密码法律、法规要求的技术保证通信过程中数据的机密性、完整性；
- b) 提供本地数据备份与恢复功能；
- c) 提供异地数据备份功能，重要数据应进行异地实时备份；
- d) 对数据备份和恢复过程进行监控；
- e) 对数据分类备份，并进行加密传输和加密存储。

7.7.2 增强要求

本项的增强要求应包括：

- a) 数据备份恢复支持自动化；
- b) 支持实时容灾切换保持业务连续运行。

7.8 资产跟踪和监测

7.8.1 一般要求

本项要求应包括：

- a) 安全保存与信息系统相关的资产清单；
- b) 监控和跟踪资产的启用到退役的全过程，并掌握资产在赛前和赛时的情况和位置。

7.8.2 增强要求

本项的增强要求应包括：

- a) 支持自动监测和发现资产变更和使用的行为。

7.9 安全审计要求

7.9.1 一般要求

本项的一般要求应包括：

- a) 审计记录应包括：事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；
- b) 配置日志服务器，日志服务器上审计记录应至少保存 6 个月；
- c) 日志服务器应能够根据记录数据进行分析，并生成审计报表；
- d) 应对审计记录进行保护，避免受到未预期的删除、修改或覆盖等。

7.9.2 增强要求

本项的增强要求应包括：

- a) 定义审计跟踪极限的阈值，当存储空间接近极限时，能采取必要的措施进行告警，当存储空间被耗尽时，终止可审计事件的发生；
- b) 采用集中日志审计设备或系统，根据统一的安全策略，实现日志的集中审计，时钟保持与时钟服务器同步。

7.10 接口安全要求

7.10.1 一般要求

本项的一般要求应包括：

- a) 提供身份认证技术和机制来实现接口用户的标识和授权；
- b) 提供访问控制技术和机制来实现不同权限的接口访问；
- c) 提供加密传输技术和机制来实现接口数据安全传输；
- d) 提供数据完整性技术和机制来实现接口的真实性和防篡改；

7.10.2 增强要求

无。